

Narrativa Explicativa: De GCI a GQM + PRAGMATIC

1. Por qué mezclar tres mundos

El GCI nos da la foto diplomática: ¿qué tan comprometido está un país con la ciberseguridad, según cinco pilares que abarcan leyes, tecnología, organización, capacidades y cooperación?[web:20] GQM nos recuerda que **no tiene sentido medir nada que no responda a una pregunta derivada de un objetivo claro**. [web:43][web:42] PRAGMATIC, por su parte, nos evita el síndrome de “métricas coleccionables”, proponiendo un filtro para distinguir métricas útiles de métricas decorativas. [web:47][web:50][web:55]

Cuando se trata de bajar de los objetivos nacionales al terreno resbaladizo de los logs y los Excel empresariales, esta tríada ofrece una brújula razonable: el **objetivo nacional** dicta la dirección, las **preguntas GQM** trazan el mapa, las **métricas PRAGMATIC** señalan qué piedras merece la pena voltear.

2. Trazabilidad: del Tier 1 al ticket de incidencia

Imaginemos el objetivo “Mantener a España en el Tier 1 del GCI”, especialmente fuerte en los pilares organizativo y de cooperación. [web:9][web:20] Este objetivo se traduce, a nivel nacional, en estrategias, programas y leyes. Pero si queremos saber si las empresas –las que operan sistemas críticos, las que gestionan datos masivos– caminan en esa dirección, necesitamos encadenar:

- Objetivo nacional: reforzar resiliencia y cooperación.
- Objetivo empresarial (pilar): mejorar la gestión de incidentes y el intercambio de información.
- Preguntas GQM: “¿detectamos los incidentes a tiempo?”, “¿compartimos información relevante con quien debemos?”.
- Métricas: MTDD/MTTR, número y calidad de notificaciones a CSIRT, participación en ejercicios conjuntos, etc.

De este modo, cuando una métrica empeora –por ejemplo, aumenta el MTDD– no solo sabemos que hay un problema operativo: sabemos que se está erosionando, en miniatura, el mismo compromiso que el GCI pretende medir a escala país.

3. La selección natural de las métricas

El enfoque PRAGMATIC introduce algo de darwinismo sano en nuestro zoo de indicadores. [web:47][web:55] No todas las métricas nacen iguales: algunas son brillantes pero carísimas; otras son baratas pero casi inútiles; algunas son fáciles de manipular, otras casi incorruptibles.

Evaluar cada métrica según:

- Qué tan bien predice futuros problemas o éxitos,
- Qué tan útil es para quien toma decisiones,
- Qué tan costoso es capturarla,

permite ir depurando el catálogo. El objetivo no es tener un dashboard barroco con 80 indicadores, sino un pequeño conjunto de métricas que verdaderamente guíen la acción, tanto en el consejo de una empresa como en un comité interministerial.

4. Asimetría de lenguajes: técnicos, gestores y reguladores

La combinación GCI + QQM + PRAGMATIC también ayuda a traducir:

- Los requisitos de marcos como NIS2, ENS y guías ENISA, que suelen hablar en términos de “medidas adecuadas”, “niveles de madurez” y “gestión de riesgos”.^{[web:35][web:40][web:41]}
- El lenguaje técnico de SOC, CSIRT y equipos de ingeniería (MTTD, MTTR, cobertura de escaneos, alertas, logs).
- Las preocupaciones de negocio y finanzas (ROI, continuidad, reputación).

QQM ofrece la gramática: **Objetivo (negocio/regulación) – Pregunta (comprensible) – Métrica (técnica y medible)**.^{[web:42][web:51][web:45]} PRAGMATIC garantiza que las métricas elegidas sirvan para algo más que llenar cuadros.

5. Un ciclo de mejora, no una foto fija

Finalmente, es importante ver este marco como un proceso iterativo:

1. Se seleccionan objetivos y preguntas.
2. Se eligen métricas candidatas y se las somete al escrutinio PRAGMATIC.
3. Se pilotan las métricas en organizaciones voluntarias.
4. Se observan efectos: ¿ayudan a tomar mejores decisiones, a priorizar inversiones, a cumplir mejor con marcos como NIS2 o ENS?
5. Se ajusta el catálogo: algunas métricas se retiran, otras se refinan, otras nacen por inspiración de incidentes reales.

Al cabo de un tiempo, el sistema nacional de métricas de ciberseguridad debería parecerse menos a un armario de indicadores y más a un **instrumento de navegación**, coherente con el espíritu del GCI y útil para quienes tienen que evitar que el barco encalle.